MacZine

THE MACTECH SOLUTIONS NEWSLETTER
ISSUE Nº 065 · OCTOBER 2026 · MACTECHSOLUTIONSLLC.COM/MACZINE

QUESTIONS · MEDIA PROTECTION

Retiring a Drive That Held CUI Under NIST 800-88 Rev. 2

NIST rewrote its media sanitization guide in September 2025. What 3.8.3 now asks of a small contractor retiring a laptop, an SSD, or a copier.

BY **MAXINE** READING TIME · 5 MIN NIST-800-171 · MEDIA-SANITIZATION · NIST-800-88 · CUI · CMMC-LEVEL-2

Every small defense contractor eventually retires a laptop that once held controlled unclassified information, and most do it with a procedure written for the hard drives of a decade ago. NIST noticed. In September 2025 it published SP 800-88 Revision 2, Guidelines for Media Sanitization, superseding the Revision 1 that had stood since December 2014, and the new edition retires several habits that small programs still treat as the safe choice.

MacZine has touched this ground once, in What Actually Makes a File CUI, which made the point in a paragraph that a drive thrown out because a program ended is a sanitization finding, not decontrol. This issue is the procedure behind that paragraph, taken one question at a time.

FIELD COPY
ISSUE Nº 065
NIST 800 171

Which edition of 800-88 do we actually follow?

Two answers coexist, and a program should know both. The rule that governs destroying CUI, 32 CFR 2002.14(f), requires destruction "in a manner that makes it unreadable, indecipherable, and irrecoverable," and where no other authority specifies a method, it points to NIST SP 800-53 and SP 800-88. The edition it incorporates, listed in 32 CFR 2002.2, is Revision 1 from December 2014. NIST's current guidance is Revision 2.

For a contractor the requirement that gets scored is NIST SP 800-171 3.8.3: "Sanitize or destroy system media containing CUI before disposal or release for reuse." It names no edition. Our reading is that a procedure written to Rev. 2, which also states that the regulation still incorporates Rev. 1, gives an assessor the most defensible record, because Rev. 2 corrects practices that Rev. 1 era procedures often got wrong. That is an editorial judgment, not a ruling, and the contract and the agency's own instructions outrank it.

Is a multi-pass overwrite still the careful choice?

No, and on modern drives it can be the careless one. Rev. 2 recalls that hard drives were once overwritten in multiple passes, sometimes citing DoD 5220.22-M, and notes that DoD removed overwriting specifications from that manual in 2006. On solid state drives with overprovisioning, it says those practices "should be avoided" because they achieve very little confidentiality protection. Flash storage keeps spare cells and levels wear across them, so the normal write interface cannot reach every place the data once lived. Running a 3-pass wipe on an SSD produces a reassuring log and can leave behind exactly the blocks the wipe never reached.

Clear, purge, or destroy?

Rev. 2 keeps the three methods. Clear uses logical techniques against all user-addressable storage and protects against simple, non-invasive recovery through the normal interface. Purge makes recovery infeasible with state-of-the-art laboratory techniques while leaving the media potentially reusable. Destroy does the same and leaves the media unable to store data again.

5

SPRS POINTS 3.8.3 CARRIES IN THE DOD ASSESSMENT METHODOLOGY, FOR SANITIZING OR DESTROYING MEDIA BEFORE DISPOSAL OR REUSE

Sept 2025

NIST SP 800-88 REV. 2 PUBLISHED, SUPERSEDING THE DECEMBER 2014 REV. 1

2014

THE 800-88 EDITION 32 CFR 2002.2 STILL INCORPORATES BY REFERENCE FOR DESTROYING CUI

◆ PAPER IS A DIFFERENT PROBLEM

Rev. 2 says the clear and purge methods are not appropriate for hard copy under any conditions. Printed CUI is destroyed or it is not sanitized at all, which is why the shredder's specification belongs in the same procedure as the drive wiper.

The guide's preference is explicit: "When possible, the purge sanitization method should be used instead of the clear sanitization method." It also narrows a tool many shops still trust. Degaussing should not be used on non-magnetic media such as SSDs, many existing degaussers lack the force for newer high-coercivity magnetic drives, and degaussing "is not considered an approved destroy sanitization technique" at the time of writing. For the techniques themselves, Rev. 2 places everything technology-specific except cryptographic erase outside its own scope and directs readers to the latest version of IEEE 2883, so a procedure built only on the 2014 edition should be checked against that standard.

Can the encryption we already run do the work?

Often, yes. Rev. 2 treats cryptographic erase as a purge technique: sanitize the keys that encrypt the data and the data becomes unrecoverable, much faster than any overwrite. The condition is the pedigree of the cryptography. For federal agencies, the guide requires encryption modules validated to the current FIPS 140 standard to have that assurance for a self-encrypting drive.

An encrypted drive is only as erasable as its key management is provable.

Contractors meet the same condition by another road. Requirement 3.13.11 already obliges FIPS-validated cryptography whenever cryptography protects CUI confidentiality, and the methodology scores it at 5 points if encryption is absent and 3 if it is present but not validated. A program that has done 3.13.11 properly has most of a cryptographic erase capability already. Cloud storage is the case where this matters most: Rev. 2 says that for logical or virtual storage, cryptographic erase may be the only viable purge option, because the data owner never touches the physical disk. Ask a provider how its key destruction works before CUI goes in, not when the subscription ends.

What about the leased copier, the warranty return, the donated laptop?

These are the releases programs forget are releases. Objective 3.8.3[b] asks whether media containing CUI is sanitized before it is released for reuse, and a copier going back to the leasing company or a failed drive shipped back under warranty is media leaving the company's control to be used again. Rev. 2 is practical about it. It names lease returns, reuse, resale and donation as reasons purge may fit better than destruction, and for office equipment that offers only a factory reset, that reset can count as clear so long as the user interface cannot retrieve the original data. Whether clear is enough for the CUI involved is a risk decision the program records, not one it skips.

What will an assessor ask to see?

The 800-171A examine list for 3.8.3 includes procedures addressing media sanitization and disposal, the applicable standards, and media sanitization records. Rev. 2 tells you what a good record holds. Its sample certificate of sanitization in Appendix C captures the person performing the work, the media's make, model and serial number, the method and technique, the tools used with their version, verification and validation results, the media's destination, and a signature with a concurrence. Rev. 2 also adds sanitization assurance as a formal step: verify the technique completed, then decide whether the outcome is acceptable, and repeat it if not.

A drawer of shredding receipts that list "12 drives" without serial numbers will not answer that list. A spreadsheet with one row per serial number, the method, the tool version and two signatures will. If you are not sure which drawer your program has, a readiness check is a quicker way to find out than the assessor's question. ◆